JEFF HANNA

Seattle, WA | LinkedIn | GitHub | Website

Security engineer who treats AI security as an extension of the fundamentals (identity, segmentation, data handling, and supply chain) and keeps digging into how agents, tools, and data really interact until the weak point is clear, then builds the control that closes it.

CORE COMPETENCIES

AI/LLM Threat Modeling and Architecture Review (OWASP LLM Top 10, MITRE ATLAS) | LLM Gateway Security and Guardrails (LiteLLM, llm-guard, Bedrock) | Agent Permissions and Identity | Prompt Injection, Excessive Agency, and Data Leakage | AI Logging, Detection, and Privacy Trade-offs | AI Vendor and SaaS Review | AWS Security (IAM, CloudWatch, GuardDuty, Security Hub) | Infrastructure as Code (Terraform) | Kubernetes and Container Security (k3s, Kyverno, Falco) | Software Supply Chain Security (SBOM, Dependency Analysis, Artifact Repositories) | Python and Go | AI Enablement and Training | Cross-Team Partnership

BEST ACCOMPLISHMENTS

- **Production LLM gateway, secured:** Threat modeled a production LLM gateway, drove new guardrails, and integrated its AI detections into the SIEM; my security vs. privacy logging recommendation was adopted.
- **Proactive supply chain defense:** Built a system that checks news and social media hourly for newly compromised packages, checks repos and assets for exposure, alerts the owning teams, and blocks bad versions before builds pull them.
- **AI enablement across an org:** Trained most of my org to build reliable AI workflows and built a Claude skill so about 50 engineers can build the same way.
- **AI risk at board level:** Write the quarterly AI threat report used in board-level reporting, including shadow AI and agent governance.
- **Guardrails built, not just specified:** Built an inline prompt injection sanitizer, llm-guard enforcement, and nightly out-of-band review for indirect injection on a self-hosted LLM stack.

WORK EXPERIENCE

Senior Security Engineer | GoDaddy **03/2022 – Present**

Security Automation and AI Pipeline Engineering 50% | *Threat Intelligence Program Ownership 30%* | *AI Security SME 10%* | *Detection and Response 10%*

- AI security SME for a production LLM gateway: threat modeled it against OWASP LLM Top 10 and MITRE ATLAS, drove a set of new guardrails, stood up out-of-band testing with the owning teams, and integrated its AI detections into the SIEM.
- Advised detection and production teams on where prompt logging should sit between security and privacy; my recommendation was adopted.
- Trained most of my org on building reliable AI workflows: stripping and compacting input, using deterministic code where it works, having models return structured output that code can check, and alerting on soft errors. Built a Claude skill so about 50 engineers can build the same way on our platforms.
- Write the quarterly AI threat report used in board-level reporting, covering emerging AI platform risk, shadow AI, and agent governance.
- Review AI features offered by SaaS vendors; so far recommended keeping that work on internal tools and models so the company keeps control of its data.
- Built a proactive supply chain compromise system that checks news, social media, and threat reporting every hour for newly compromised packages, checks them against code repositories, SBOM and dependency data, and endpoint and SIEM telemetry, and routes each hit to the right owner: product security for affected repos, vulnerability management for affected assets, and the operations center for active exposure.
- Ran this year's major npm, GitHub Actions, and PyPI compromises through it end to end, hunting malicious downloads across developer machines and cloud assets, blocking malicious versions in the artifact repository before builds could pull them, and requesting emergency upgrades wherever a compromised version was in use.
- Built AI-assisted pipelines that turn raw threat reporting into enriched findings, executive and engineering reports, and detection content, including an agentic enrichment loop that calls threat intel APIs as tools. Filtering plus TOON compaction cut model input by over 99%.

- Built quality controls into every AI step: model or deterministic code chosen per step by reliability, cross-checked outputs with agreement scoring, hard and soft error logging with timing, parse failures flagged instead of passed on, and a QA system that compares filtered output to the unfiltered feed to find false positives and collection gaps.
- Traced a silent production failure through another team's code and cloud logs to its root cause, exposing a logging gap that the owning team closed with new alerting.
- Supported 30+ incidents and initiated 7 directly from proactive hunting; served a quarter as acting manager and returned to IC work by choice.

Intelligence Directorate Branch Supervisor | U.S. Cyber Command (TS/SCI, inactive) 12/2017 – 10/2021

- Built hunt packages for Cyber National Mission Force Hunt Forward Operations in 28 countries, mapping nation-state infrastructure and tradecraft.
- Built the command's first OSINT program, including process, tooling, governance, and data quality standards; managed 500+ products read by the Commander, NSA Director, and the President.
- Led 6 analysts investigating APTs, malware, and intrusions.

Intelligence and Cyber Programs Manager | Washington Army National Guard (TS/SCI, inactive) 03/2015 – 10/2022

- Built CTI and information security programs from scratch and led up to 50 people across partner organizations.

PERSONAL PROJECTS

AI Security Layer for a Self-Hosted LLM Stack (public on GitHub): LiteLLM gateway with a custom sanitizer for prompt injection, steganographic signals, and hostile HTML; synchronous llm-guard enforcement; a nightly out-of-band model-based review for indirect injection and context manipulation; and three-tier privacy logging (metadata and hashes, encrypted raw, flagged retention) with Vault Transit break-glass. Runs on k3s with Kyverno and Falco eBPF, all rebuildable from Terraform and shell, with 18 architecture decision records.
Locked-Down Coding Agent Environment (in progress): treats a coding agent as a process that runs as me and can be steered by prompt injection. Designed root-owned hooks that block package installs and secret access, one pre-approved environment with offline package managers, keychain-held keys, and a local LiteLLM proxy as the only path for model traffic using revocable, budgeted keys. Built so far: per-call logging and a nightly local-model summarizer.
Agentic IAM (independent research, in progress): access control design for AI agents built on the fundamentals: just-in-time grants, capability tokens, delegation that can only narrow, attested agent identity, a budgeted human approval tier, and policy as code, with controls that degrade instead of halting.
CTI as Code (built, private): runs a threat intelligence program as version-controlled records checked in CI by a validator, publication gates, and a sanitizer, so the program can move at machine speed.

EDUCATION AND PROFESSIONAL DEVELOPMENT

Master of Cybersecurity and Leadership – University of Washington (GPA: 3.85)
Cloud Security Graduate Certificate – SANS Technology Institute (2026)
Cybersecurity Engineer Graduate Certificate – SANS Technology Institute (2024)

Certifications:
CISSP | GMLE | GCSA | GPCS | GCLD | GCIH | GCIA | GCTI | GSEC

PROFESSIONAL ORGANIZATIONS

Project Management Institute (PMI) | Women in Cybersecurity (WiCyS) | CompTIA | National Diversity Council | National Guard Association of Washington (NGAW)